

Lineamientos de Seguridad de la Información en los procesos de Adquisición, Desarrollo y Mantenimiento de Software en Cartones América		
Objetivo:	Definir los lineamientos de Seguridad de la Información en los procesos de Adquisición, Desarrollo y Mantenimiento de Software en Cartones América, con el objetivo de implementar controles para mitigar riesgos y dar cumplimiento a las Políticas de Seguridad de la Información de la organización.	
Empresa a evaluar		
Software, Sistema de Información y/o Plataforma:		
Nota:		Calificación: SI = 1 No = 0
		Por favor cuando sea necesario justifique su respuesta

[Volver al Menu](#)

	DESCRIPCIÓN DEL REQUISITO	CALIFICACIÓN	OBSERVACIONES
RECURSO HUMANO Y SEGURIDAD DE LA INFORMACIÓN			
1	¿El personal se encuentra capacitado en seguridad de la información y conoce sus buenas practicas?	1	Adjunto nuestra norma: NO-SI-05- Concientizacion y Capacitacion de Seguridad_v2.1_14-11-2024.pdf
2	¿Se realizan capacitaciones de sensibilización en seguridad de la información, ciberseguridad y seguridad informatica?	1	Adjunto nuestra norma: NO-SI-05- Concientizacion y Capacitacion de Seguridad_v2.1_14-11-2024.pdf
3	¿Existe una politica de seguridad, establecida, publicada, mantenida y divulgada a todo el personal pertinente?	1	Adjunto: PO-SI-01- Seguridad de la informacion_2024-10-08_v3.0.pdf
4	¿Se desarrollan políticas de utilización para tecnologías críticas para definir el uso adecuado de dichas tecnologías?	1	Adjunto: - NO-TI-01- Uso de Recursos Informáticos - PO-SI-03- Seguridad en el Uso de Inteligencia Artificial
5	¿Se cuenta una política de uso aceptable de la tecnología?	1	Adjunto: - NO-TI-01- Uso de Recursos Informáticos - PO-SI-03- Seguridad en el Uso de Inteligencia Artificial
6	¿La empresa que buenas practicas de seguridad aplica?	1	Adjunto nuestra política de seguridad que define los lineamientos que aplicamos para la gestión de la seguridad de la información: PO-SI-01- Seguridad de la informacion_2024-10-08_v3.0.pdf
7	¿Se encuentra certificada en alguna norma?	1	ISO 27001:2022 Adjunto certificado: INTIZA Certificados 27001_2025.pdf
8	¿Se tienen definidos los riesgos y controles de seguridad de la información?	1	Adjunto: NO-SI-04- Gestión de Riesgo del SGSI_2024-11-21_v3.0.pdf
9	¿Se cuenta con un procedimiento de gestión de incidentes de seguridad de la información y ciberseguridad?	1	Adjunto: NO-SI-10- Gestión de Incidentes de Seguridad_V2.1_2024-08-22.pdf
CIFRADO			
1	¿Los servidores donde esta alojada la aplicación estan protegidos contra la manipulación de medios extraibles?	1	
2	Los datos de información personal almacenados en las base de datos, deben estar enmascarados, con algoritmos fuertes y contraseñas robustas.	1	Todos los datos están cifrados en reposo y en tránsito. Adjunto: NO-SI-20 Cifrado de la Información_v1.1_2024-07-10.pdf
3	¿Utilizan tipo de cifrado TLS3 o superior para la transferencia de información?	0	Intiza tiene homologado cifrado TLS 1.2 Adjunto: NO-SI-20 Cifrado de la Información_v1.1_2024-07-10.pdf
4	El canal de comunicación debe estar cifrado, cuando se transmiten/intercambian datos de información personal.	1	Todos los datos están cifrados en reposo y en tránsito. Adjunto: NO-SI-20 Cifrado de la Información_v1.1_2024-07-10.pdf
5	El acceso administrativo que no es desde consola, se cifra de manera segura? En observaciones indique que tecnologías utiliza SSH, VPN, SSL/TLS	1	VPN
COPIAS DE SEGURIDAD			
1	¿Se realizan las copias de seguridad?	1	Adjunto: NO-SI-15 Resguardo y Recupero de la Información_2024-07-16_v1.1.pdf
2	Las copias de seguridad se estan realizando en data center externo o interno mediante cintas?	0	No se manejan backups fisicos.
3	Que tipos de copia de Seguridad se realizan? Completa, diferencial o incremental? Justificar respuesta	1	Se realizan resguardos diarios de la totalidad de la información de los clientes de la compañía, los mismos son incrementales y se mantiene una copia semanal durante al menos un año.
4	Que herramienta de copias de seguridad utilizan? Justificar Respuesta	1	Utilizamos backups nativos de Azure y de MSQl.
5	¿Las copias de seguridad se realizan de forma diaria?	1	Adjunto: NO-SI-15 Resguardo y Recupero de la Información_2024-07-16_v1.1.pdf
6	¿Se cuenta con politicas para el respaldo de la información y procedimientos de restauración de los datos?	1	Adjunto: NO-SI-15 Resguardo y Recupero de la Información_2024-07-16_v1.1.pdf
7	¿Se realizan pruebas de comprobación de datos al menos 1 vez por semestre?	0	Formalizamos, de acuerdo a nuestra norma, que el mismo sea anual. Adjunto: NO-SI-15 Resguardo y Recupero de la Información_2024-07-16_v1.1.pdf
HERRAMIENTAS DE SEGURIDAD			
1	¿Cuantan con herramientas de seguridad?	1	Nos apalancamos en todo el sistema de seguridad de Azure: Sentinel, End Point Protection, Defender, etc.
2	¿Esta la autenticación de dos factores incorporada a la red de empleados, administradores y terceros para el acceso remoto?	1	
3	¿Se instala software antivirus en todos los sistemas?	1	Adjunto: NO-TI-03- Software Malicioso_v2.1_2025-05-02.pdf
4	¿Todos los programas antivirus son capaces de detectar, eliminar y proteger contra todos los tipos conocidos de software malicioso?	1	Adjunto: NO-TI-03- Software Malicioso_v2.1_2025-05-02.pdf
5	¿La política antivirus requiere actualizaciones y sus definiciones?	1	Adjunto: NO-TI-03- Software Malicioso_v2.1_2025-05-02.pdf
6	¿Todos los programas antivirus son capaces de detectar, eliminar y proteger contra todos los tipos conocidos de software malicioso?	1	Adjunto: NO-TI-03- Software Malicioso_v2.1_2025-05-02.pdf
7	¿Estan habilitadas las actualizaciones automaticas y los escaneos periodicos?	1	
CONTROL DE ACCESO			
1	Los medios de almacenamiento cuentan con medidas de seguridad físicas (incluyendo, sin sentido limitativo, a computadoras, medios extraíbles electrónicos, recibos de papel e informes de papel)	1	
2	¿Se lleva un control estricto sobre la distribución interna o externa de cualquier tipo de medios?	1	Intiza es un sistema SaaS. No manejamos medios fisicos.
3	¿Están clasificados los medios de manera que se pueda determinar la confidencialidad de los datos?	1	Adjunto: PR-SI-14 Clasificación de Activos de la Información_v1.2_2025-02-19.pdf

4	¿Se lleva un control estricto sobre el almacenamiento y accesibilidad de los medios?	1	Intiza es un sistema SaaS. No manejamos medios físicos.
5	¿Se destruyen todos los medios cuando ya no son necesarios por razones comerciales o legales?	1	Adjunto: NO-SI-19 Retención y Eliminación de Información_v2.1_2025-02-25.pdf
6	¿Se debe otorgar privilegios de acceso a la información a los usuarios, según las funciones del cargo (roles y perfiles)?	1	Adjunto: NO-SI-02- Gestión de Cuentas de Usuarios_2025-11-11_v2.pdf
7	La herramienta cuenta con un módulo de administración de usuarios, que permita segregar las funciones según las responsabilidades asignadas (administradores, usuarios, auditor, etc).	1	Esto se configura junto con el cliente en la etapa de implementación de Intiza.
8	Cuando la herramienta detecta varios intentos fallidos de autenticación se realiza el bloqueo?	1	Esto se configura junto con el cliente en la etapa de implementación de Intiza.
9	Se cuenta con un timeout de sesión inicial de 5 minutos de inactividad?	1	Esto se configura junto con el cliente en la etapa de implementación de Intiza.
10	El portal web permite a través del navegador almacenar el histórico de usuarios autenticados?	0	
11	La plataforma donde se implemente la solución debe permitir la configuración de listas de control de acceso (listas blancas de dominios de confianza).	1	
REDES			
1	¿Las redes se encuentran segmentadas?	1	
2	¿Se protege el acceso a internet y de que manera?	1	Firewalls y reglas NSG.
3	Se detectan las Tarjetas WLAN insertadas en los componentes del sistema?	1	No aplica para Intiza. No tenemos ambiente físico. Es una herramienta Cloud.
4	Se detectan dispositivos inalámbricos portátiles conectados al sistema, por ejemplo usb?	1	No aplica para Intiza. No tenemos ambiente físico. Es una herramienta Cloud.
5	Se detectan dispositivos inalámbricos conectados a un puerto de red o aun dispositivo de red?	1	No aplica para Intiza. No tenemos ambiente físico. Es una herramienta Cloud.
6	¿Se restringen las configuraciones para firewall y routers entre redes no confiables?	1	Firewalls y reglas NSG.
7	¿Está el tránsito entrante y saliente restringido a la cantidad que sea necesaria en el entorno desarrollo y se documentan las restricciones?	1	
8	¿Están instalados firewalls de perímetro entre las redes inalámbricas?	1	
9	¿Las cuentas utilizadas por los proveedores para el acceso remoto, el mantenimiento o soporte estan habilitadas solo durante el periodo de tiempo necesario?	1	
10	¿Prohíbe la configuración de firewall el acceso directo público?	1	
11	¿Las cuentas de acceso remoto de los proveedores son supervisadas solo cuando estan utilizandose?	1	Adjunto: NO-SI-12- Monitoreos de Eventos y Análisis de Logs_2025-02-24_v2.1.pdf
AUDITORIA DE SEGURIDAD			
1	Los logs de auditoria almacenan errores que se presentan en las herramientas?	1	
2	Los logs de auditoria almacena la actividad de los usuarios finales y usuarios administradores	1	
3	Los logs de auditoria almacenan la creación, modificación, habilitación, deshabilitación y eliminación de privilegios de Acceso?	1	
GESTIÓN DE VULNERABILIDADES			
1	¿Se cuenta con una política que garantice que los sistemas operativosy software instalados se encuentren con los parches mas recientes?	1	Adjunto: NO-SI-13 Gestión de Vulnerabilidades y Parches_v2.1_2024-08-09.pdf
2	¿Se instalan parches de seguridad critica en un lapso de un mes contado a partir de su fecha de lanzamiento?	1	Los parches de seguridad se aplican en forma automática los miercoles de cada semana.
3	¿Se cuentan con mejores practicas de desarrollo de codigo seguro?	1	Adjunto: NO-SI-21 Desarrollo seguro_v3_2024-07-10.pdf
4	¿Se tienen en cuenta estándares de configuración segura en los servidores de aplicación y base de datos. (Guías de Hardening)?	1	
5	Garantizar que los cambios realizados en los sistemas de información se revisan realizando un procedimiento de escaneo de vulnerabilidades para detectar código malicioso y estableciendo planes de remediación.	1	Adjunto: NO-TI-04 Gestión de Cambios_v2.2_2025-10-28.pdf
6	El fabricante de los componentes de la solución debe proporcionar actualizaciones periódicas de seguridad y remediación de vulnerabilidades encontradas.	1	
GENERALIDADES			
1	¿Si se cuenta con una integración con plataformas de CAME, estas fueron autorizadas previamente por el equipo de TI? Favor suministrar al formulario el VoBo.	1	
2	¿Se cuenta con plan de continuidad de negocio?	1	Adjunto: PO-TI-01- Continuidad de Procesamiento de Datos_v2.1_2024-11-25.pdf
3	¿Se cuenta con un plan de continuidad tecnológica para garantizar la continuidad del servicio?	1	Adjunto: PO-TI-01- Continuidad de Procesamiento de Datos_v2.1_2024-11-25.pdf
4	¿Se cuentan con políticas para el respaldo de información y procedimientos de restauración de los datos?	1	Adjunto: NO-SI-15 Resguardo y Recupero de la Información_2024-07-16_v1.1.pdf
5	¿Se encuentran definidos los ANS de disponibilidad?	1	
6	Se cuenta con un inventario de activos de información con el fin de identificar la información y valorarla según su nivel de criticidad?	1	Adjunto: NO-SI-17 Gestión de Activos de la Información_2024-09-10_v1.1.pdf
7	Requerimientos legales, regulatorios y normativos: acuerdos de confidencialidad, circulares, Ley Habeas Data (1582), etc.	1	
8	¿Se cuenta con los controles CCM v 3.0.1-Cloud. (Políticas de Seguridad en la Nube). ?	1	Adjunto: NO-SI-27- Norma de Seguridad Cloud.pdf
9	¿Se cuenta con una política de desarrollo?	1	Adjunto: NO-SI-21 Desarrollo seguro_v3_2024-07-10.pdf
10	¿Se cuenta con un mecanismos para validación de datos con el fin de evitar la introducción de datos incorrectos en las bases de datos y garantizar la integridad de la información?	1	
11	Si la herramienta se encuentra implementada o se encuentra en proceso de implementación, esta permite la integración con el directorio activo?	1	Intiza se integra via SAML.

CALIFICACIÓN

94%